CzarIntel Compliance Control Matrix

> This matrix maps **HIPAA Security Rule**, **SOC 2 (2017 TSC)**, **PCI DSS v4.0** and **NIST SP 800-53 Rev. 5** requirements to the exact files in this repository that implement them.
>
> **Automated** means `scripts/compliance_scan.py` checks the control on every PR and every night, and the build fails on regression. **Structural** means Terraform, policy or configuration enforces the control, and review plus `terraform validate`, checkov, tflint and ansible-lint gate it.
>
> **Important:** a landing zone enables compliance but does not confer it. Administrative safeguards (risk assessment, workforce training, BAAs, incident-response exercises, vendor management) remain the client’s responsibility. They are listed in §4 so that no gap is implied to be covered.

---

1. Technical control matrix

1.1 Access control and identity

Control objective	HIPAA	SOC 2	PCI DSS 4.0	NIST 800-53	Implementation (file → resource)	Evidence
Unique identity and SSO with MFA for all humans	164.312(a)(2)(i), 164.312(d)	CC6.1	8.2.1, 8.4.2	IA-2, IA-2(1)	`terraform/modules/azure/main.tf` → AKS `azure_active_directory_role_based_access_control`, `local_account_disabled = true`; Grafana `auth.azuread` in `monitoring/prometheus/values-override.yml`	Entra sign-in logs
Role-based least privilege	164.308(a)(4), 164.312(a)(1)	CC6.1, CC6.3	7.2.1, 7.2.2	AC-2, AC-3, AC-6	`kubernetes/rbac/roles.yml` (platform-admins / sre / developers / auditors), `argocd/projects/czarintel-project.yml` roles	`kubectl auth can-i --list` per group
No static cloud credentials:	164.312(d)	CC6.1	8.3.1, 8.6.3	IA-5(7), IA-9	IRSA `aws_iam_role.api_ser`	**TF-002** (automated),

Control objective	HIPAA	SOC 2	PCI DSS 4.0	NIST 800-53	Implementation (file → resource)	Evidence
workload identity federation					`vice` / `.jenkins_agent`; Azure `azurread_application_federated_identity_credential`; GCP `google_service_account_iam_binding` (Workload Identity); GitHub OIDC in `.github/workflows/platform-quality.yml`	**AWS-006** (automated)
Root / privileged account protection	164.312(a)(1)	CC6.1	8.4.1	IA-2(1), AC-6(5)	Account baseline, checked nightly	**AWS-005** (automated)
SSH hardening: no root login, keys only	164.312(d)	CC6.1	8.2.1, 8.3	AC-17, IA-5	`ansible/roles/cis_hardening/templates/sshd_config.j2`	**SSH-001**, **SSH-002** (automated)
Session and account lockout	164.312(a)(2)(iii)	CC6.1	8.3.4, 8.2.8	AC-7, AC-11, AC-12	`ansible/roles/cis_hardening/tasks/ac-`	ansible-lint and Molecule-ready role

Control objective	HIPAA	SOC 2	PCI DSS 4.0	NIST 800-53	Imple-menta-tion (file → re-source)	Evidence
policy on hosts					`counts.yml` (pam_faillock, TMOUT, password ageing)	

1.2 Network security and segmentation

Control objective	HIPAA	SOC 2	PCI DSS 4.0	NIST 800-53	Imple-menta-tion	Evidence
Default-deny east-west traffic	164.312(e)(1)	CC6.6	1.3.1, 1.3.2	SC-7, AC-4	`kuber-netes/network-policies/default-deny.yml`, Jenkins policies in `ci-cd/jenkins/jenkins-deploy-ment.yml`	**K8S-006** (auto-mated)
Private compute and data tiers	164.312(e)(1)	CC6.6	1.4.1, 1.4.4	SC-7(5)	AWS private subnets, RDS `pub-licly_acce ssible = false`; GKE `private_cl uster_conf ig`; AKS authorised IP ranges	checkov
Default security group locked down	—	CC6.6	1.2.1	SC-7	`aws_defaul t_security _group.def ault` (CIS AWS 5.4)	checkov CKV2_AWS _12
Network traffic log-ging	164.312(b)	CC7.2	10.2.1	AU-12, SI-4	`aws_flow_l og.main` (ALL traffic → KMS Cloud-Watch)	Cloud-Watch log group
Public ac-cess	164.312(a)(1)	CC6.6	1.3.1	AC-3, SC-7	`aws_s3_buc ket_public _ac-`	

Control objective	HIPAA	SOC 2	PCI DSS 4.0	NIST 800-53	Imple-menta-tion	Evidence
blocked on storage					`cess_block .backups` / `.auto-` GCS `pub-lic_access _preven-tion = "en-forced"`	**AWS-003** (auto-mated)

1.3 Workload and configuration integrity

Control objective	HIPAA	SOC 2	PCI DSS 4.0	NIST 800-53	Implementation	Evidence
Non-root containers	164.312(a)(1)	CC6.1	2.2.5	AC-6, CM-7	Helm `securityContext`, `docker/*/Dockerfile` `USER 10001`	**K8S-001**, **DOCKER-001**
No privileged / host-namespace pods	164.312(a)(1)	CC6.8	2.2.1, 2.2.5	AC-6(10), SC-39	PSA `restricted` in `kubernetes/namespaces.yml`	**K8S-002**, **K8S-007**
Immutable, read-only runtime	164.312(c)(1)	CC6.8	2.2	CM-7, SI-7	`readOnlyRootFilesystem: true` in all charts and Jenkins	**K8S-005**
Resource limits (DoS resilience)	164.308(a)(7)	A1.1	6.4	SC-5	Requests and limits in every chart, HPA	**K8S-003**
Pinned, approved images only	164.312(c)(1)	CC8.1	6.3.2	CM-2, SI-7, SR-3	Gatekeeper `approved-registries-only`, `block-latest-tag`; ECR `IMMUTABLE`; GKE Binary Authorization	**K8S-004**, **DOCKER-002**
Mandatory ownership	—	CC1.3, CC2.1	12.5.1	CM-8, PM-5	Gatekeeper `work-`	Gatekeeper audit

Control objective	HIPAA	SOC 2	PCI DSS 4.0	NIST 800-53	Implementation	Evidence
and cost labels					`loads-must-have-ownership-labels`, Terraform `common_tags`	
CIS-hardened hosts	164.308(a)(1)(ii)(B)	CC7.1	2.2.1	CM-6, CM-7	`ansible/roles/cis_hardening` (filesystems, services, sysctl, auditd, SSH, accounts), `ansible/roles/docker_hardening`	ansible-lint production profile
Configuration as code, peer-reviewed	164.308(a)(8)	CC8.1	6.5.1, 6.5.2	CM-3, CM-5	Terraform + ArgoCD `selfHeal: true` (drift reverted); `terraform-validate.yml`	Git history, ArgoCD sync history

1.4 Vulnerability and change management

Control objective	HIPAA	SOC 2	PCI DSS 4.0	NIST 800-53	Imple-menta-tion	Evidence
Image and depend-ency CVE scanning gate	164.308(a)(1)(ii)(A)	CC7.1	6.3.1, 11.3.1	RA-5, SI-2	`ci-cd/Jen-kinsfile` Trivy im-age ‖ Trivy fs/secrets; ECR `scan_on_pu sh`	Jenkins artefacts
Secret scanning	164.312(a)(1)	CC6.1	8.3.2	IA-5(7)	Trivy `--scanners secret`, compli-ance scan-ner `TF-002`	**TF-002**
IaC secur-ity scan-ning	164.308(a)(1)(ii)(A)	CC7.1	6.3.1	RA-5, CM-6	checkov, tflint in `.github/workflows/terraform-valid-ate.yml`	SARIF up-load
Segreg-ated envir-onments	164.308(a)(4)	CC8.1	6.5.3, 6.5.4	CM-4, SC-32	Work-spaces dev/stg/prod; namespac es with `czarin-tel.io/en-vironment`; ArgoCD AppProject destina-tions	Gatekeep-er `namespaces-must-declare-environ-ment`
Pull-based deploy: CI has no prod	164.312(a)(1)	CC8.1	6.5.6	AC-5, CM-5	Jenkins → GitOps commit → ArgoCD	Jenkinsfile, `argocd/ap-plications/*`

Control objective	HIPAA	SOC 2	PCI DSS 4.0	NIST 800-53	Imple-menta-tion	Evidence
cluster cre-dentials						

1.5 Data protection

Control objective	HIPAA	SOC 2	PCI DSS 4.0	NIST 800-53	Imple-menta-tion	Evidence
Encryption at rest with customer-managed keys	164.312(a)(2)(iv)	CC6.1	3.5.1	SC-28, SC-12	AWS KMS CMK with rotation (RDS, EKS secrets, S3, logs, SNS); Azure Key Vault premium; GCP Cloud KMS 90-day rota-tion (GKE secrets, GCS, BigQuery)	**TF-003**, **AWS-004**, **AWS-007**, **TF-001**
Encryption in transit	164.312(e)(1), 164.312(e)(2)(ii)	CC6.7	4.2.1	SC-8, SC-8(1)	RDS `re-quire_secu re_transpo rt` ; S3 policy denies non-TLS; TLS ingress (cert-man-ager) on `*.czarin-tel.io`	Bucket policy, parameter group
Backup and recov-erability	164.308(a)(7)(ii)(A)	A1.2	12.10.1	CP-9, CP-10	RDS Multi-AZ, PITR, `backup_ret en-tion_perio d` ; S3/GCS versioned backups with life-cycle; `de-le-tion_prote`	DR run-book

Control objective	HIPAA	SOC 2	PCI DSS 4.0	NIST 800-53	Implementation	Evidence
					`ction` in prod	
Minimum-necessary analytics (de-identified)	164.514(b)	C1.1	3.3, 3.4	PT-2, SC-28	BigQuery dataset description policy, templated `route` column (never raw path), partition expiry	`terraform/modules/gcp/main.tf`
Key custody and deletion protection	164.312(a)(2)(iv)	CC6.1	3.6.1, 3.7	SC-12	KMS 30-day deletion window; Key Vault purge protection; GCP keys `prevent_destroy`	Terraform plan

1.6 Logging, monitoring and incident detection

Control objective	HIPAA	SOC 2	PCI DSS 4.0	NIST 800-53	Imple-menta-tion	Evidence
API audit trail, tamper-evident	164.312(b)	CC7.2	10.2.1, 10.3.2, 10.5.1	AU-2, AU-9, AU-11, AU-12	`aws_cloudtrail.main` (multi-region, log-file validation, KMS, 6-year retention)	**AWS-001**
Kubernetes control-plane audit logs	164.312(b)	CC7.2	10.2.1	AU-12	EKS `enabled_cluster_log_types` includes `audit`; AKS diagnostic settings	CloudWatch / Log Analytics
Host audit logging	164.312(b)	CC7.2	10.2.1.2	AU-2, AU-12	`ansible/roles/cis_hardening/templates/audit.rules.j2` → Fluent Bit → Loki (90-day hot retention)	Loki
Threat detection	164.308(a)(1)(ii)(D)	CC7.2, CC7.3	11.5.1	SI-4, IR-4	GuardDuty (S3, EKS audit, RDS, EBS malware, runtime) → EventBridge → SNS; Defender for Containers	**AWS-002**

Control objective	HIPAA	SOC 2	PCI DSS 4.0	NIST 800-53	Imple-menta-tion	Evidence
Availability monitoring and alert-ing	164.308(a)(7)	A1.1, A1.2	10.7.2	SI-4, CP-2	`monitor-ing/pro-metheus/custom-rules/api-alerts.yml` (SLO burn-rate, MySQL, nodes); Grafana dash-boards	**DOCK-ER-003**; dash-boards
Time syn-chronisa-tion	164.312(b)	CC7.2	10.6.1	AU-8	`ansible/roles/cis_harden ing/tem-plates/chrony.con f.j2`	ansible
Continuous compli-ance pos-ture	164.308(a)(8)	CC4.1	12.4.2	CA-7	`scripts/compli-ance_scan.py` in CI (PR and nightly) → Security Posture dashboard	CI arte-facts

2. Automated check catalogue

Check	Title	Severity	NIST	PCI	SOC 2	HIPAA
K8S-001	Containers must run as non-root	high	AC-6, CM-7	2.2.5	CC6.1	164.312(a)(1)
K8S-002	Privileged containers / privilege escalation forbidden	critical	AC-6(10)	2.2.5	CC6.8	164.312(a)(1)
K8S-003	CPU/memory limits required	medium	SC-5	6.4	A1.1	164.308(a)(7)
K8S-004	Images must be pinned (no :latest)	high	CM-2, SI-7	6.3.2	CC8.1	164.312(c)(1)
K8S-005	Read-only root filesystem	medium	CM-7, SI-7	2.2	CC6.8	164.312(c)(1)
K8S-006	Namespaces must have a default-deny NetworkPolicy	high	SC-7, AC-4	1.3	CC6.6	164.312(e)(1)
K8S-007	hostNetwork/hostPID/hostIPC forbidden	critical	SC-39	2.2.1	CC6.8	164.312(a)(1)
DOCKER-001	Dockerfile must switch to a non-root USER	high	AC-6	2.2.5	CC6.1	164.312(a)(1)
DOCKER-002		medium	CM-2	6.3.2	CC8.1	164.312(c)(1)

Check	Title	Severity	NIST	PCI	SOC 2	HIPAA
	Base image must be pinned					
DOCKER-003	HEALTHCHECK defined	low	SI-4	10.6	A1.2	164.308(a)(7)
TF-001	Terraform state backend encrypted	high	SC-28	3.5	CC6.1	164.312(a)(2)(iv)
TF-002	No hard-coded credentials in Terraform	critical	IA-5(7)	8.3.1	CC6.1	164.312(d)
TF-003	Storage/database encryption at rest enabled	high	SC-28	3.5	CC6.1	164.312(a)(2)(iv)
SSH-001	SSH root login disabled in baseline	high	AC-6(2), AC-17	8.2.1	CC6.1	164.312(a)(1)
SSH-002	SSH password authentication disabled	high	IA-2, IA-5	8.3	CC6.1	164.312(d)
AWS-001	Multi-region CloudTrail logging enabled	critical	AU-2, AU-12	10.2	CC7.2	164.312(b)
AWS-002	GuardDuty enabled	high	SI-4	11.5	CC7.2	164.308(a)(1)(ii)(D)
AWS-003	S3 buckets block public access	critical	AC-3, SC-7	1.3.1	CC6.6	164.312(a)(1)

Check	Title	Severity	NIST	PCI	SOC 2	HIPAA
AWS-004	S3 buckets encrypted by default	high	SC-28	3.5	CC6.1	164.312(a)(2)(iv)
AWS-005	Root account MFA enabled	critical	IA-2(1)	8.4	CC6.1	164.312(d)
AWS-006	IAM access keys rotated within 90 days	medium	IA-5(1)	8.3.9	CC6.1	164.308(a)(5)(ii)(D)
AWS-007	EBS encryption by default	high	SC-28	3.5	CC6.1	164.312(a)(2)(iv)

Run the checks locally:

```
python3 scripts/compliance_scan.py repo --fail-on medium            # static repo
checks
python3 scripts/compliance_scan.py aws --region us-east-1 --format json -o
scan.json   # live account
```

The scanner prints a per-framework list of failing control IDs, for example `{"HIPAA": [], "NIST": [], ...}`. Auditors can use that list directly as evidence of continuous monitoring.

---

3. Framework coverage summary

Framework	Technical families covered in this repo
HIPAA Security Rule	§164.308(a)(1) risk management (tooling), (a)(4) access management, (a)(7) contingency; §164.312(a) access control, (b) audit controls, (c) integrity, (d) authentication, (e) transmission security
SOC 2	CC6 (logical access), CC7 (system operations), CC8 (change management), A1 (availability), C1 (confidentiality), CC4.1 (monitoring)
PCI DSS 4.0	Req. 1 (network controls), 2 (secure config), 3 (stored data), 4 (transit), 6 (secure development), 7–8 (access and identity), 10 (logging), 11.3/11.5 (vuln scanning, detection)
NIST 800-53 r5	AC, AU, CA-7, CM, CP-9/10, IA, IR-4, PT-2, RA-5, SC, SI, SR-3

4. Client-owned responsibilities (not implemented by code)

Area	HIPAA	SOC 2	PCI DSS	NIST	Notes
Business Associate Agreements with AWS, Microsoft and Google	164.308(b)	CC9.2	12.8	SA-9	Sign the BAA in each provider console before loading PHI
Formal risk assessment	164.308(a)(1)(ii)(A)	CC3.2	12.3.1	RA-3	Scanner output is an input to it, not a substitute
Workforce security training	164.308(a)(5)	CC1.4	12.6	AT-2	—
Incident-response plan and tabletop exercises	164.308(a)(6)	CC7.4	12.10	IR-8	See ../runbooks/incident-response.md for technical playbooks
Penetration testing	—	CC4.1	11.4	CA-8	Annual, and after significant change
Physical security	164.310	CC6.4	9	PE	Inherited from cloud providers (SOC 2 Type II / PCI AoC)